SEZIONE B: Analisi Tecnica e Forense dell'Incidente

Destinatario: IT Manager / SOC Team Leader **Rif. Incidente:** #20240115-TN (Workstation WKST-HR-04)

1. Introduzione e Metodologia:

In data 15/01 /2024 alle 09:16 è stata ricevuta una mail di phishing dalla WKST-HR-04 nella quale si richiedeva il pagamneto di una fattura insoluta, nella suddetta fattura vi era un allegato contenete un file zip chiamato “Fattura_Insoluta_ Gennaio.zip” protetto da password con grandezza 24 KB.

2. Analisi del Vettore d'Attacco:

L'attaccante ha sfruttato una combinazione di urgenza e autorità ("Ultimo avviso", "Sospensione entro 2 ore") per indurre l'utente Marco Rossi ad aprire l'allegato Fattura_Insoluta_Gennaio.zip.
Il file ZIP è stato fornito con protezione tramite password (12345).

3. Analisi del malware:

Dall'analisi del log al timestamp 2024-01-15T09:16:12.450Z, osserviamo il primo fallimento delle difese: scan_skipped

"File scan skipped. Archive is password protected. Unable to inspect content."

L'Antivirus aziendale è stato neutralizzato dalla crittografia del file ZIP, permettendo al file malevolo di introdursi nella cartella C:\Users\mrossi\Downloads\ senza alcuna ispezione del contenuto.

Time line:

L’utente scarica l’allegato contenuto nella mail:
"@timestamp": "2024-01-15T09:16:12.450Z",
"host": { "name": "WKST-HR-04", "ip": "192.168.10.45" },

L’utente apre l’allegato:

"@timestamp": "2024-01-15T09:17:05.112Z",
"event": { "category": "process", "type": ["start"] },
"process": {
"name": "Fattura_Insoluta_Gennaio.pdf.exe",
"pid": 4490

Effettuata analisi auristica con risultato 45/100:

"@timestamp": "2024-01-15T09:17:08.220Z",
"event": { "category": "malware", "action": "heuristic_analysis", "outcome": "allowed" },
"rule": { "name": "Heuristic_Pre_Execution", "score": 45 },
"message": "Process allowed. Heuristic score (45/100) below blocking threshold. No static signature match found.",
"process": { "pid": 4490, "name": "Fattura_Insoluta_Gennaio.pdf.exe" }

Collegamento ad IP riconducibile a nodo TOR presso Panama:

"@timestamp": "2024-01-15T09:17:30.005Z",
"event": { "category": "network", "type": ["connection"] },
"destination": {
"ip": "185.200.118.44",
"port": 443,
"geo": { "country_name": "Panama" },
"threat_intel": { "indicator": "Tor Exit Node", "confidence": "High" }

Modifica di 50 file /s compreso Report_Q4.xlsx:

"@timestamp": "2024-01-15T09:17:31.550Z",
"event": { "category": "file", "action": "modification_bulk" },
"file": {

"path": "C:\\Users\\mrossi\\Documents\\Report_Q4.xlsx",
"target_path": "C:\\Users\\mrossi\\Documents\\Report_Q4.xlsx.crypt"
},
"message": "High frequency file modification detected (50 files / 1s)."

Rilevazione ransomware e processo di stop fallito:

"@timestamp": "2024-01-15T09:17:32.100Z",
"event": { "category": "intrusion_detection", "severity": "critical", "action": "quarantine_failed" },
"rule": { "name": "Ransomware_Behavior_Killswitch", "technique_id": "T1486" },
"process": { "pid": 4490 },
"message": "CRITICAL: Ransomware behavior detected. Attempted to kill process PID 4490. Status: FAILED."

4. Network & Threat Intelligence

Dal momento in cui la workstation 04 ha scaricato e aperto l'allegato della mail infetta non si poteva fare piu niente. L'unico modo sarebbe stato prevenire chiamando l'azienda che in teoria ha mandato la mail e chiedere direttamente a loro se fosse effettivamente una loro comunicazione.

5. Remediation

Per prevenire il ripetersi di tali incidenti, si propone:

1° Formazione obbligatoria per tutti i dipendenti con particolare attenzione ai reparti che possono essere più soggetti ad attacchi.
2° Abbassare la soglia di criticità per cui il firewall non si attiva (al disotto di 40/100) ed inserire i file zip
3° Scollegare immediatamente la workstation 04 da qualsiasi rete interna ed esterna
4° Bloccare la connessione della rete verso qualsiasi nodo Tor (noto per essere usato per scopi malevoli)
5° Fare backup quotidiano di tutti i dati